09 - Security, Privacy and Medical Safety

Medical safety controls

Generated 2026-10-14 from 09-SECURITY-AND-PRIVACY.md - information only, not medical advice.

Contents

Threats (STRIDE-style summary)

Privacy

Platform hardening

Known gaps

Risk	Control	Evidence
Missed emergency	Rules (12 categories, draft pending clinician review) + LLM second opinion; either fires; code-built notice first; survives provider outage	`tests/safety/test_emergency_triage.py`, safety suite
Self-harm	Crisis resources, no generated content	safety suite
Diagnosis	Scope class + output detector removes diagnostic sentences + referral	`test_answer_checks.py`
Prescribing / dosing	Doses only as verbatim cited quotes; otherwise refusal; pharmacist warning	safety suite incl. adversarial model
Hallucination	Citation, number, drug-name checks; faithfulness judge on high-risk topics (fail closed); "not covered" without sources	`test_chat_end_to_end.py`
Outdated guidance	Staleness flag; newest version preferred; conflicts stated	`test_retrieval_quality.py`

Threats (STRIDE-style summary)

Threat	Mitigation
Spoofing	Supabase JWT via JWKS, ES256/RS256 only (HS256/none rejected), audience/issuer/expiry checked
Elevation	Roles only from `app_metadata`; RBAC dependency on every route; owner checks return 404
Prompt injection (direct)	Input policy blocks injection/jailbreak patterns + LLM scope classifier
Prompt injection (indirect)	Document/web guard neutralises instruction lines, flags chunks, prompt labels them untrusted
Information disclosure	Local PHI redaction before any egress; output PHI/secret redaction; prompt-leak block; no PHI in logs/metrics/audit
Tampering	Parameterised SQL; LLM cache only deserialises plain text; strict CSP; text-node-only UI
DoS / abuse	Per-user rate limits (429 + Retry-After), upload size limits, circuit breakers

Privacy

- **Minimisation:** names, IDs/MRN, DOB, phone, email, addresses, national IDs redacted per `policy.yaml`.
- **Third parties:** question text (redacted) and passages -> model provider chain; uploads (redacted) -> embedding provider; research queries -> Tavily. Confirm each provider's data-processing agreement before any real PHI.
- **Encryption:** TLS (ALB, Postgres `sslmode=require`), Supabase at-rest encryption, Fernet for stored messages, KMS for EKS secrets/ECR (planned infra).
- **Retention & rights:** 30-day conversation purge; user-initiated deletion of history and uploads.
- **Audit:** one line per request + per action (who, what, outcome) without question/answer text; switchable.

Platform hardening

Non-root uid 10001, read-only root FS, no capabilities, seccomp RuntimeDefault, Pod Security "restricted", default-deny NetworkPolicies (backend reachable only from frontend + monitoring; Redis only from backend), secrets created by CD from GitHub environment secrets, Trivy gate on fixable HIGH/CRITICAL, pre-push scan for keys and patient-like data.

Known gaps

Red-flag rules need clinician sign-off; pattern redaction can miss unusual PHI formats (paired with minimisation and provider DPAs); Docker images not yet built locally (Docker Desktop unavailable).